

Q1. Deploying SonarQube and Scanning a Vulnerable Repository. Static Code Analysis with SonarQube on a Vulnerable Web Application. This lab focuses on deploying SonarQube and scanning the Damn Vulnerable Python Web App (DVPWA) repository.

Tasks:

Part 1: Deploy SonarQube dashboard & Access the Dashboard

Part 2: Prepare the Vulnerable Repository

Part 3: Create a SonarQube Project with Token

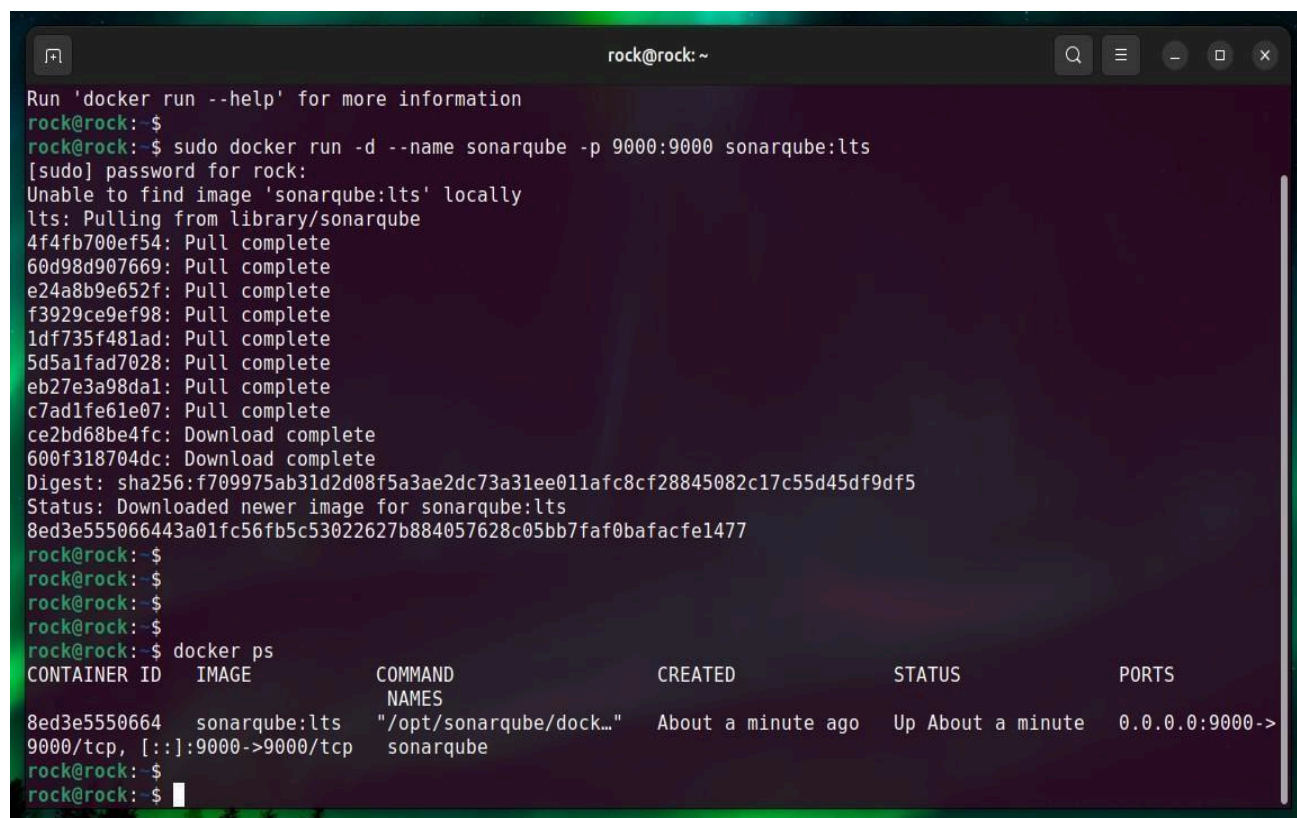
Part 4: Set Up and Run the SonarScanner

Part 5: Run the Scan

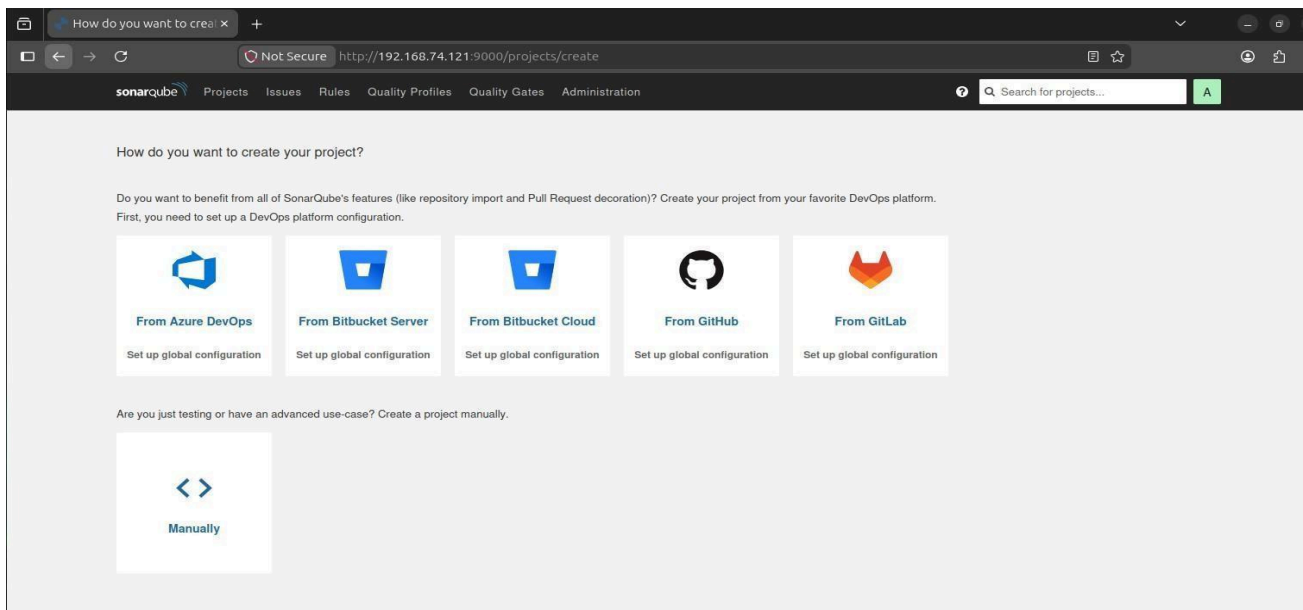
Part 6: Review Scan Results

Ans:

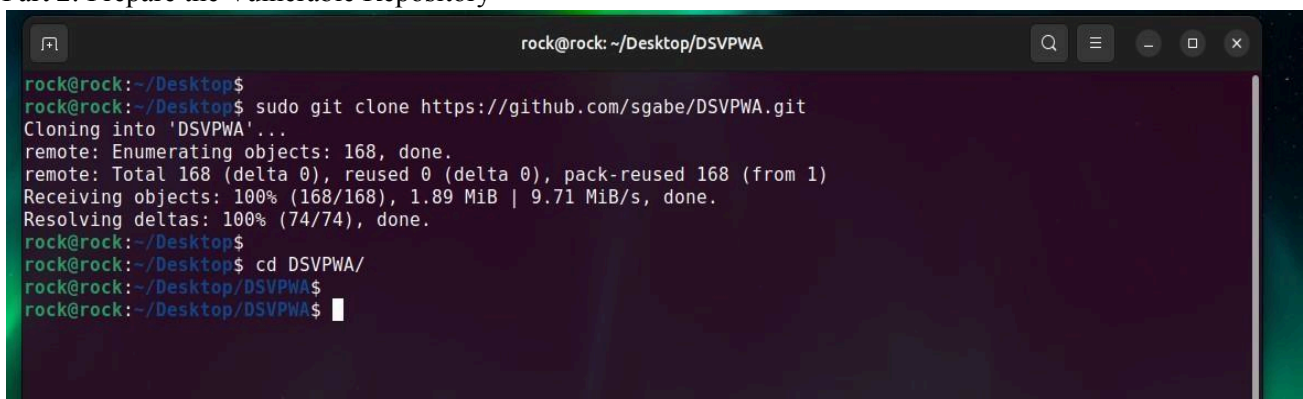
Part 1: Deploy SonarQube dashboard & Access the Dashboard



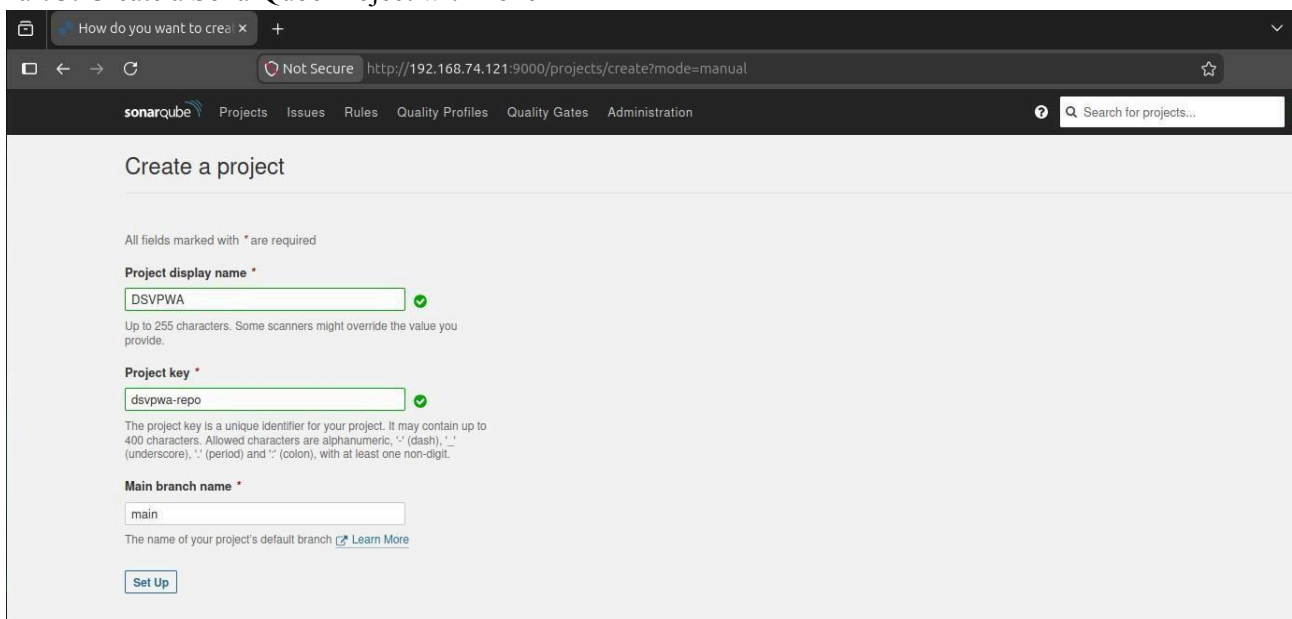
```
rock@rock: ~  
Run 'docker run --help' for more information  
rock@rock:~$  
rock@rock:~$ sudo docker run -d --name sonarqube -p 9000:9000 sonarqube:lts  
[sudo] password for rock:  
Unable to find image 'sonarqube:lts' locally  
lts: Pulling from library/sonarqube  
4f4fb700ef54: Pull complete  
60d98d907669: Pull complete  
e24a8b9e652f: Pull complete  
f3929ce9ef98: Pull complete  
1df735f481ad: Pull complete  
5d5a1fad7028: Pull complete  
eb27e3a98da1: Pull complete  
c7ad1fe61e07: Pull complete  
ce2bd68be4fc: Download complete  
600f318704dc: Download complete  
Digest: sha256:f709975ab31d2d08f5a3ae2dc73a31ee011afc8cf28845082c17c55d45df9df5  
Status: Downloaded newer image for sonarqube:lts  
8ed3e55066443a01fc56fb5c53022627b884057628c05bb7faf0bafacfe1477  
rock@rock:~$  
rock@rock:~$  
rock@rock:~$  
rock@rock:~$  
rock@rock:~$ docker ps  
CONTAINER ID   IMAGE          COMMAND                  CREATED        STATUS        PORTS  
8ed3e550664   sonarqube:lts  "/opt/sonarqube/dock..." About a minute ago Up About a minute 0.0.0.0:9000->9000/tcp, [::]:9000->9000/tcp  
rock@rock:~$  
rock@rock:~$
```



Part 2: Prepare the Vulnerable Repository



Part 3: Create a SonarQube Project with Token



DSVPWA

Not Secure http://192.168.74.121:9000/dashboard?id=dsvpwa-repo&selectedTutorial=local

sonarqube Projects Issues Rules Quality Profiles Quality Gates Administration ? Search for projects... A

DSVPWA main

Overview Issues Security Hotspots Measures Code Activity Project Settings Project Information

Analyze your project

We initialized your project on SonarQube, now it's up to you to launch analyses!

1 Provide a token

Generate a project token

Token name

Expires in

scanner-token 30 days Generate

Please note that this token will only allow you to analyze the current project. If you want to use the same token to analyze multiple projects, you need to generate a global token in your user account. See the documentation for more information.

The token is used to identify you when an analysis is performed. If it has been compromised, you can revoke it at any point in time in your user account.

2 Run analysis on your project

DSVPWA

Not Secure http://192.168.74.121:9000/dashboard?id=dsvpwa-repo&selectedTutorial=local

sonarqube Projects Issues Rules Quality Profiles Quality Gates Administration ? Search for projects..

DSVPWA main

Overview Issues Security Hotspots Measures Code Activity Project Settings

Analyze your project

We initialized your project on SonarQube, now it's up to you to launch analyses!

1 Provide a token

scanner-token: sqp_4ade71d442cfd502bbe87e488105c4acddebe234

The token is used to identify you when an analysis is performed. If it has been compromised, you can revoke it at any point in time in your user account.

Continue

2 Run analysis on your project

Part 4: Set Up the SonarScanner and Run the Scan

```
rock@rock: ~/Desktop/DSVPWA
rock@rock: ~/Desktop/DSVPWA$ sudo docker run --rm --network="host" -v "$(pwd):/usr/src" sonarsource/sonar-scanner-cli \
-Dsonar.projectKey=dsvpwa-repo \
-Dsonar.sources=. \
-Dsonar.host.url=http://192.168.74.121:9000 \
-Dsonar.login=sqp_4ade71d442cfd502bbe87e488105c4acddebe234
06:18:46.753 INFO Scanner configuration file: /opt/sonar-scanner/conf/sonar-scanner.properties
06:18:46.758 INFO Project root configuration file: NONE
06:18:46.778 INFO SonarScanner CLI 8.0.1.6346
06:18:46.783 INFO Linux 6.17.0-35-generic amd64
06:18:48.491 INFO Communicating with SonarQube Server 9.9.8.100196
06:18:49.578 INFO Load global settings
06:18:50.585 INFO Load global settings (done) | time=1008ms
06:18:50.588 INFO Server id: 147B411E-AZ8XFahGtgEluapWxwv
06:18:50.596 INFO User cache: /opt/sonar-scanner/.sonar/cache
06:18:50.602 INFO Load/download plugins
06:18:50.602 INFO Load plugins index
06:18:52.156 INFO Load plugins index (done) | time=1554ms
06:18:54.777 INFO Load/download plugins (done) | time=4175ms
06:18:55.253 INFO Process project properties
06:18:55.264 INFO Process project properties (done) | time=11ms
06:18:55.270 INFO Execute project builders
06:18:55.271 INFO Execute project builders (done) | time=2ms
06:18:55.275 INFO Project key: dsvpwa-repo
06:18:55.275 INFO Base dir: /usr/src
06:18:55.275 INFO Working dir: /tmp/.scannerwork
06:18:55.289 INFO Load project settings for component key: 'dsvpwa-repo'
06:18:56.684 INFO Load project settings for component key: 'dsvpwa-repo' (done) | time=1395ms
06:18:56.863 INFO Load quality profiles
```

```
rock@rock: ~/Desktop/DSVPWA
06:19:35.540 INFO Sensor IaC Docker Sensor [iac]
06:19:35.545 INFO 1 source file to be analyzed
06:19:35.645 INFO 1/1 source file has been analyzed
06:19:35.645 INFO Sensor IaC Docker Sensor [iac] (done) | time=105ms
06:19:35.661 INFO ----- Run sensors on project
06:19:35.734 INFO Sensor Analysis Warnings import [csharp]
06:19:35.739 INFO Sensor Analysis Warnings import [csharp] (done) | time=4ms
06:19:35.739 INFO Sensor Zero Coverage Sensor
06:19:35.762 INFO Sensor Zero Coverage Sensor (done) | time=23ms
06:19:35.765 INFO SCM Publisher SCM provider for this project is: git
06:19:35.767 INFO SCM Publisher 18 source files to be analyzed
06:19:36.417 INFO SCM Publisher 18/18 source files have been analyzed (done) | time=650ms
06:19:36.433 INFO CPD Executor 2 files had no CPD blocks
06:19:36.433 INFO CPD Executor Calculating CPD for 12 files
06:19:36.538 INFO CPD Executor CPD calculation finished (done) | time=82ms
06:19:36.637 INFO Analysis report generated in 94ms, dir size=259.3 kB
06:19:36.695 INFO Analysis report compressed in 58ms, zip size=96.3 kB
06:19:37.461 INFO Analysis report uploaded in 765ms
06:19:37.465 INFO ANALYSIS SUCCESSFUL, you can find the results at: http://192.168.74.121:9000/dashboard?id=dsvpwa-repo
06:19:37.465 INFO Note that you will be able to access the updated dashboard once the server has processed the submitted analysis report
06:19:37.465 INFO More about the report processing at http://192.168.74.121:9000/api/ce/task?id=AZ8XLUtCtgEluapWx6qK
06:19:38.190 INFO Analysis total time: 43.271 s
06:19:38.194 INFO EXECUTION SUCCESS
06:19:38.195 INFO Total time: 51.445s
rock@rock: ~/Desktop/DSVPWA$
rock@rock: ~/Desktop/DSVPWA$
rock@rock: ~/Desktop/DSVPWA$
```


Part 5: Review Scan Results

 Projects Issues Rules Quality Profiles Quality Gates Administration

DSVPWA main

Overview Issues Security Hotspots Measures Code Activity Project Settings Project Information

QUALITY GATE STATUS

Passed
All conditions passed.

MEASURES

New Code	Overall Code
1 Bugs	Reliability E
0 Vulnerabilities	Security A
7 Security Hotspots	0.0% Reviewed Security Review E
4h 14min Debt	25 Code Smells Maintainability A
0.0% Coverage on 427 Lines to cover	10.5% Duplications on 1.3k Lines
- Unit Tests	6 Duplicated Blocks

Issues

Not Secure

http://192.168.74.121:9000/project/issues?id=dsvpwa-repo&resolved=false

sonarqube

Projects

Issues

Rules

Quality Profiles

Quality Gates

Administration

?

Search for projects...

A

DSVPWA

main

Last analysis of this Branch had 2 warnings

June 30, 2026 at 11:48 AM

Version not provided

Overview

Issues

Security Hotspots

Measures

Code

Activity

Project Settings

Project Information

My Issues

All

Filters

Issues in new code

Type

Bug

Vulnerability

Code Smell

Severity

Blocker

Critical

Major

Scope

Resolution

Status

Security Category

Creation Date

Language

Rule

Tag

Bulk Change

dsvpwa.py

Remove this unneeded "pass".

Code Smell

Minor

Open

Not assigned

2min effort

Comment

4 years ago

L47

unused

dsvpwa/attacks.py

Add a nested comment explaining why this method is empty, or complete the implementation.

Code Smell

Critical

Open

Not assigned

5min effort

Comment

4 years ago

L28

suspicious

Remove parameter handler or provide default value.

Code Smell

Critical

Open

Not assigned

15min effort

Comment

4 years ago

L33

suspicious

Rename this variable; it shadows a builtin.

Code Smell

Major

Open

Not assigned

5min effort

Comment

4 years ago

L37

bad-practice, confusing, pitfall

Remove parameter handler or provide default value.

Code Smell

Critical

Open

Not assigned

15min effort

Comment

4 years ago

L68

suspicious

Remove parameter handler or provide default value.

Code Smell

Critical

Open

Not assigned

15min effort

Comment

4 years ago

L81

suspicious

Remove parameter handler or provide default value.

Code Smell

Critical

Open

Not assigned

15min effort

Comment

4 years ago

L115

suspicious

Remove parameter handler or provide default value.

Code Smell

Critical

Open

Not assigned

15min effort

Comment

4 years ago

L131

suspicious

Security Hotspots

Not Securehttp://192.168.74.121:9000/security_hotspots?id=dsvpwa-repo

sonarcubeProjectsIssuesRulesQuality ProfilesQuality GatesAdministration

Search for projects...A

DSVPWAmain

Last analysis of this Branch had 2 warningsJune 30, 2026 at 11:48 AMVersion not provided

OverviewIssuesSecurity HotspotsMeasuresCodeActivity

Project SettingsProject Information

FiltersAssigned to meAllStatusTo reviewOverall codeSecurity Hotspots Reviewed0.0%

"password" detected here, make sure this is not a hard-coded credential.
db/users.xml

Review priority: MEDIUM

Permission2

Make sure that recursively copying directories is safe here.
Dockerfile

The python image runs with root as the default user. Make sure it is safe here.
Dockerfile

Weak Cryptography1

Make sure that using this pseudorandom number generator is safe here.
dsvpwa/handlers.py

7 of 7 shown

Make sure that using this pseudorandom number generator is safe here.

Using pseudorandom number generators (PRNGs) is security-sensitivepython:S2245

Status: TO REVIEW

This security hotspot needs to be reviewed to assess whether the code poses a risk.

Change status

Assignee: Not assigned

Where is the risk?What's the risk?Assess the riskHow can I fix it?

dsvpwa/handlers.pyOpen in IDEGet Permalink

192self.end_headers()
193self.wfile.write(content)
194self.wfile.flush()
195
196def do_GET(self):
197self.params = urlparse.parse_qs(urlparse.urlparse(self.path).query)
198self.path = self.path.split('?')[0]
199self.cookie.load(self.headers.get('Cookie', ''))
200
201if not self.cookie and '/login' == self.path:
202token = ''.join(random.sample(string.ascii_letters + string.digits, 20))
203
204self.cookie.load('SESSIONID={}'.format(token))

Make sure that using this pseudorandom number generator is safe here.Comment